

AI Trust Graph: Executive Brief

Graph-based, evidence-bounded assurance for connected AI systems

Siva Sethumadhavan

Executive brief, version 1.0 · October 2026 Derived from: *AI Trust Graph: A Graph-Driven, Evidence-Based Methodology for AI Assurance*, Whitepaper version 1.0, <https://doi.org/10.5281/zenodo.23104503>
Methodology baseline: bundle 1.0-rc.4 (public-release candidate)

This brief summarizes the whitepaper for executives, boards and governance leaders. It adds no claim, definition or rule of its own. Where the brief and the whitepaper differ, the whitepaper prevails, and the governed methodology artifacts prevail over both.

© 2026 Siva Sethumadhavan. Licensed under the Creative Commons Attribution 4.0 International License (CC BY 4.0), <https://creativecommons.org/licenses/by/4.0/>. The licence does not grant rights to the "AI Trust Graph" name or any future logo or wordmark, which are reserved (see TRADEMARKS.md in the methodology repository), and it does not authorize any conformance or certification claim, which Artifact #11 governs. Independent research; the views are the author's own and imply no endorsement by any employer, client or cited organization. Provided as is, without warranty.

1. Why this matters

Most AI risk reviews still look at one component at a time: is the model approved, is the application registered, is authentication on, does the data platform have access controls? Each answer can be "yes" while the connected system still produces a consequential outcome.

AI-enabled services are now compositions of identities, agents, tools, retrieval systems, data, providers, workflows and human approval points. Exposure often arises from how those parts are joined:

- an agent acts through a privileged service identity rather than the user's own permissions;
- a retriever can read sources its user cannot open, so restricted content reaches the user through the assistant;
- an approved integration gives an agent a path to a third-party tool that can change an enterprise record;
- text inside a retrieved document steers an agent that holds authority, even though the text itself holds none.

None of these is visible from a component inventory or a control checklist alone. The whitepaper's thesis is that AI risk does not emerge exclusively from models. It emerges through relationships among humans, identities, agents, tools, models, data, providers, infrastructure and business systems.

2. What AI Trust Graph does

AI Trust Graph (ATG) is an open, vendor-neutral methodology that represents an AI-enabled environment as a graph of connected objects and assesses it along one reasoning chain:

Objects -> Relationships -> Conditions -> Paths -> Authority and Influence -> Consequence -> Controls -> Evidence -> Decision



Canonical reasoning chain — Artifact #2 §0.10

Figure 1. Canonical reasoning chain (whitepaper Figure 1).

In plain terms: establish what exists and how it is connected; state the conditions under which a connection can actually be used; follow the paths those connections form; ask who or what can cause or steer an outcome along each path, and how much it would matter; identify the controls that can stop, constrain, detect or contain progression; and accept only those conclusions the evidence supports, before an accountable person decides what to do.

Four distinctions that the methodology requires to remain explicit matter most for decision-makers:

Canonical distinction	What it means for a decision
Connectivity / Authorization	A system that can reach another system is not thereby permitted to act on it.
Authorization / Invocation	Holding a grant does not show that the action occurred.
Invocation / Consequence	A call that occurred does not show a material effect.
Finding / Decision	Management can accept, treat or defer a risk, but a decision cannot rewrite the assessed condition.

The method also separates **trust** (relying on another party or output for a defined purpose) from **authority** (the capacity to access, influence or change a target), and recognizes **influence**: the ability to affect behaviour or output without necessarily holding formal access. Indirect prompt injection through retrieved content is a concrete example of influence without authority.

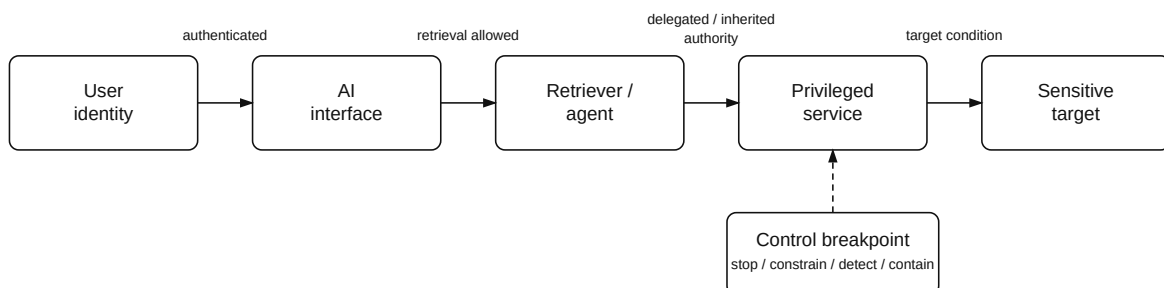


Figure 2. Illustrative path reasoning with explicit conditions, authority and candidate control breakpoints (whitepaper Figure 2).

3. The questions every connected-AI decision should be able to answer

For any material AI use case, ATG is designed to answer:

1. What can this component reach?
2. Through which identity, and under what authority?
3. Across which boundaries, for example a provider, account, privilege or data-classification boundary?
4. Under what preconditions: permissions, protocol, state, approval, timing?
5. Which control would stop, constrain, detect or contain the path, and is there evidence that it actually operates?
6. What evidence supports each step?
7. What remains unresolved?

4. What an assessment produces

An ATG assessment follows a thirteen-phase lifecycle from Initiate to Reassess, with a named gate at every phase. Its outputs are designed for decision-makers, not only for engineers:

- **A six-domain profile.** The domains are coordinated lenses over one graph: Discovery and AIBOM; Trust and Privilege Paths; Authority Governance; AI Security Validation; AI Governance and Assurance; Operational Resilience. Seventy-two canonical controls sit across them. The profile shows uneven capability rather than averaging it into one number.
- **A path portfolio.** Each material path carries a validation state, from Candidate through Validated, Exploitable, Controlled or Invalidated, and a role: primary, alternate or residual. A controlled primary route does not hide an uncontrolled alternate.
- **Findings separated from decisions.** Evidence gaps, control deficiencies and path exposures are recorded as findings; acceptance, exceptions and treatment are recorded as decisions with an accountable owner.
- **A report that discloses its limits.** Reporting must show critical gates, coverage and residual uncertainty rather than reduce the result to a traffic light.
- **Traceability.** A decision can be traced back through the finding, the path or control state, the graph context and the evidence to the original scope and claim.

5. How to read the results

Leaders should expect, and insist on, five reading rules:

- **UNKNOWN is a result, not a value to be filled in by default.** UNKNOWN means the evidence is absent, insufficient or materially conflicting. It is never treated as zero, safe, passed, failed, effective, low risk, Not Applicable or Not Tested.
- **Strong evidence is not necessarily good news.** Evidence grades E0 to E5 describe how well a claim is supported, not whether the result is favourable. Strong evidence can confirm that a control is not working; weak evidence cannot justify a strong assurance conclusion.
- **Maturity is not an average.** Maturity M1 to M5 is cumulative, evidence-gated and non-compensating: advanced capability in one area does not compensate for a missing foundation.

- **There is no overall trust score.** The methodology deliberately publishes none.
- **PEI is for triage, not prediction.** The Path Exposure Index ranks determinate paths for attention. It does not prove exploitability, probability or loss. An author-performed sensitivity analysis found that small changes to its weights reorder only a small share (1.3-2.2%) of path pairs, but that its bands are sensitive at their edges, so the band should always be read with the underlying component profile.

6. Where it fits

ATG is designed to complement, not replace, established frameworks such as the NIST AI Risk Management Framework, ISO/IEC 42001 and ISO/IEC 23894, MITRE ATLAS and OWASP's agentic-security guidance. It addresses a narrower question: how connected trust, authority and exposure relationships are represented, linked to controls and evidence, and turned into bounded conclusions. Its outputs can provide evidence to broader governance, risk and security processes.

Appropriate uses include:

- deciding whether a connected AI use case may proceed, and under which conditions;
- reassessing after a material change such as a new provider, permission, model version, tool, data source or incident;
- deciding which material paths to validate or remediate first;
- supplying traceable evidence, from system structure to accountable decisions, to broader governance, risk and security processes.

7. What it is not, and its current status

AI Trust Graph is not a product, a certification, a regulatory standard, or a guarantee of security, safety or compliance. It is independent research, published as a public-release candidate methodology. The author's internal review is complete. Independent methodology and AI-security reviews, an inter-assessor reproducibility study and legal approval of the licence and trademark position are pending. Its worked material is synthetic calibration, not field evidence. Discovery can be incomplete, so not finding a path is not evidence that no path exists, and agentic systems that compose tool paths at runtime and probabilistic AI guardrails remain open methodology questions.

8. Questions to ask your teams

These questions follow directly from the methodology and can be asked of any connected AI deployment today:

1. Which of our AI agents or automations can approve, execute, modify, delete, disclose or transact, and through which identities?
2. Where does an agent act on behalf of a user or another identity, and is that delegation bounded, attributable and revocable?
3. Is any "human approval" in our AI workflows meaningful: does the reviewer have the information, decision freedom, competence, time and enforceable ability to stop the action, or is an AI recommendation being treated as an approval?
4. For our most consequential AI paths, which control actually breaks the path, and what current evidence shows that it operates?

5. If that control fails, is there an alternate route to the same target?
6. Which material conditions are currently UNKNOWN, and who owns resolving them?
7. Can we revoke, contain and recover from an AI agent's actions, and has that been tested?
8. When we accept an AI risk, does the record keep the underlying finding visible?

Further reading

- Whitepaper: *AI Trust Graph: A Graph-Driven, Evidence-Based Methodology for AI Assurance*, version 1.0, <https://doi.org/10.5281/zenodo.23104503>
- Canonical methodology artifacts, bundle 1.0-rc.4: <https://github.com/Sivas1187/Ai-trust-graph>
- Website: <https://aitrustgraph.org>